

Pass-the-Hash Validation Evidence Report

Internal Network & Active Directory Pentest Evidence Documentation

Field	Details
Test Area	Pass-the-Hash validation
Evidence Source	17-pass-the-hash-system-shell-obtained.png
Result Type	PTH access validated
Primary Tool / Component	Impacket psexec / wmiexec style validation
MITRE ATT&CK Mapping	T1550.002 - Pass the Hash
Document Purpose	Professional GitHub-ready evidence report with redacted screenshot and interpretation.

This report documents one specific evidence row from the AD Network assessment. It is intentionally evidence-specific, not a generic attack tutorial. Sensitive values have been blurred or represented as redacted placeholders for safe portfolio publication.

1. Embedded Evidence Screenshot

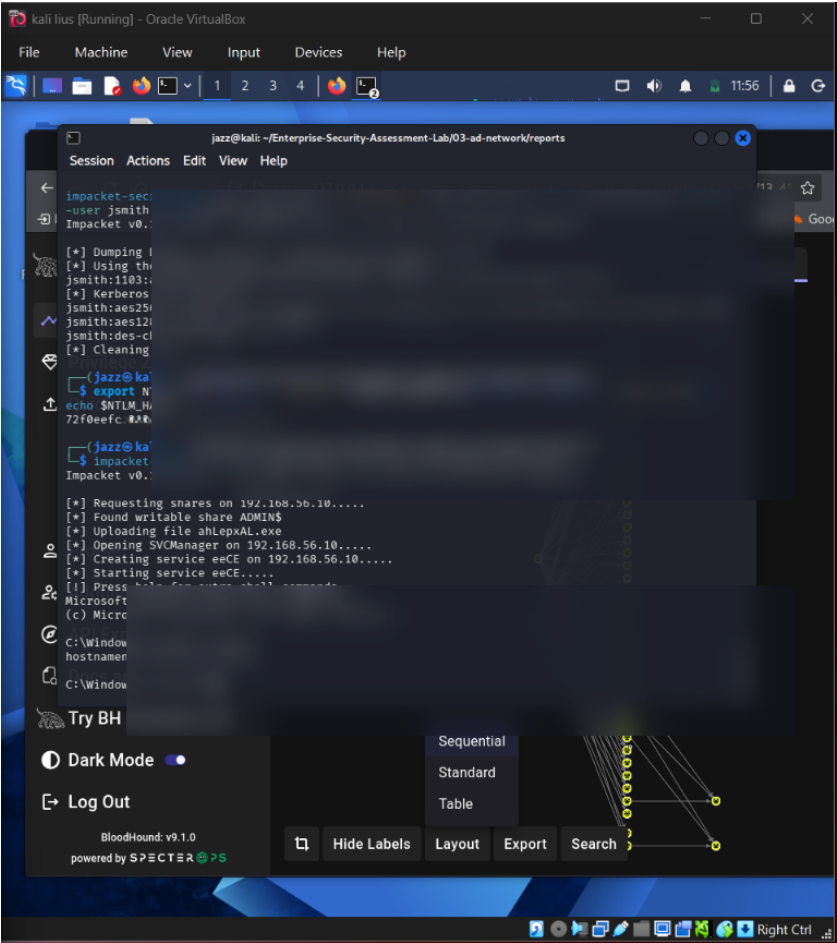


Figure 1 - Redacted evidence screenshot: 17-pass-the-hash-system-shell-obtained.png

What this screenshot proves

The screenshot shows Pass-the-Hash style access being validated in the AD lab. Hash material and sensitive command output are blurred.

Evidence Context

Area	Value
Testing Phase	Alternate Authentication Material Testing
Tool / Component	Impacket psexec / wmiexec style validation
Objective	Validate whether NTLM hash material can be used for authentication in the lab without knowing the plaintext password.
Result Type	PTH access validated

2. Evidence-Specific Methodology

This section explains how this evidence fits into the overall internal network and Active Directory attack path. The goal is to demonstrate professional testing logic, not simply show a terminal screenshot.

- Use lab-only hash material obtained during the assessment.
- Attempt authentication using hash-based credentials.
- Validate the resulting access level in the controlled lab.
- Redact hashes and shell details before publishing.

Command / Workflow Used

```
psexec.py <DOMAIN>/<USER>@<TARGET_IP> -hashes :<REDACTED_NTLM_HASH>  
whoami  
hostname
```

Sanitized Output Style

Authenticated using NTLM hash material. Shell/context validated in lab with sensitive details redacted.

Assessment Interpretation

The evidence supports the result type: PTH access validated. In a professional assessment, this evidence would be paired with the exact testing scope, timestamps, target identifiers, and remediation ownership. For GitHub publication, the report intentionally avoids showing live secrets, passwords, hashes, or reusable credential material.

3. Risk Analysis

If NTLM hashes are obtained, attackers may authenticate without plaintext passwords. Privileged hashes can enable lateral movement and host compromise.

Why this matters in enterprise AD environments

- Active Directory attacks often chain multiple medium-risk issues into domain compromise.
- Credential material, even when not plaintext, can become dangerous if cracking, relaying, or alternate authentication is possible.
- Graph-based permissions and relationship analysis is necessary because AD risk is often hidden in group nesting and delegated rights.
- Evidence must be documented clearly so defenders can connect the technical finding to a specific control gap.

Recommended Remediation

- Reduce NTLM usage where possible.
- Enable Windows Defender Credential Guard.
- Deploy LAPS/Windows LAPS for local admin accounts.
- Avoid password reuse across systems.
- Monitor remote admin logons and suspicious service creation.

Detection and Monitoring Opportunities

- Correlate authentication events with unusual source hosts and off-hours activity.
- Monitor SMB, LDAP, Kerberos, and replication-related event patterns.
- Alert on abnormal use of administrative protocols and credential dumping indicators.
- Review domain privilege assignments and privileged group membership changes regularly.

4. GitHub Publication and Redaction Guidance

This report is prepared for safe GitHub portfolio publication. The embedded screenshot has been treated as evidence, but sensitive material must not be recoverable or readable.

Sensitive Item	Action for GitHub
NTLM / NetNTLMv2 hashes	Blur or remove completely. Never publish reusable hash material.
Kerberos TGS / krb5tgs values	Blur or replace with <REDACTED_TICKET>.
Plaintext passwords	Do not publish. Replace with <REDACTED_PASSWORD>.
DCSync / NTDS hashes	Treat as domain compromise material and fully redact.
Internal IPs / domain names	May remain for lab context, but redact if privacy is required.
Username / service accounts	Keep only if lab-only; otherwise redact or generalize.

Suggested GitHub Link

[Open Report](./reports/evidence/08-pass-the-hash-validation-evidence-report.pdf)

Professional Note

This document should be stored with the AD Network module reports, preferably under 03-ad-network/reports/evidence/. It is designed to replace a plain screenshot filename in the Evidence-Based Testing Summary table with a professional clickable report.